

Enhanced Attack Report

Pygmy Goat

Generated on 2025-10-10

Disclaimer

This report has been generated automatically and should be used for informational purposes only. To generate this report, Large Language Models (LLMs) were used to analyze the provided data. This technology is not perfect and may generate incorrect or misleading results. The results should be reviewed by a human expert before taking any action based on the information provided.

Definitions

Pre-Conditions: Conditions that must be true to execute the attack steps in the milestone.

Post-Conditions: Traces that an attacker leaves behind after executing the attack steps in the milestone.

Attack Steps: Steps that an attacker would take to achieve the goal of the milestone.

MITRE Technique: Techniques from the MITRE ATT&CK; framework that are relevant to the milestone.

STIX

Malware Name: Pygmy Goat

Malware Description: Uses LD_PRELOAD to get loaded into /bin/sshd and hook its accept function. Listens on a raw socket for incoming ICMP packets to trigger a connect back, or uses the hooked accept function to search for a magic header in ssh connections. Functionality includes remote shell, packet capture, cron tasks, and creating a reverse SOCKS proxy server.

Quick Overview

Milestone m1

- a1. Command and Scripting Interpreter: Unix Shell as used by the malware (T1059.004)
- a2. Scheduled Task/Job: Cron as used by the malware (T1053.003)
- a3. Inter-Process Communication as used by the malware (T1559)

Milestone m2

- a4. Hijack Execution Flow: Dynamic Linker Hijacking as used by the malware (T1574.006)
- a5. Boot or Logon Initialization Scripts as used by the malware (T1037.005)

Milestone m3

- a6. Network Sniffing as used by the malware (T1040)

Milestone m4

- a7. Archive Collected Data: Archive via Library as used by the malware (T1560.002)

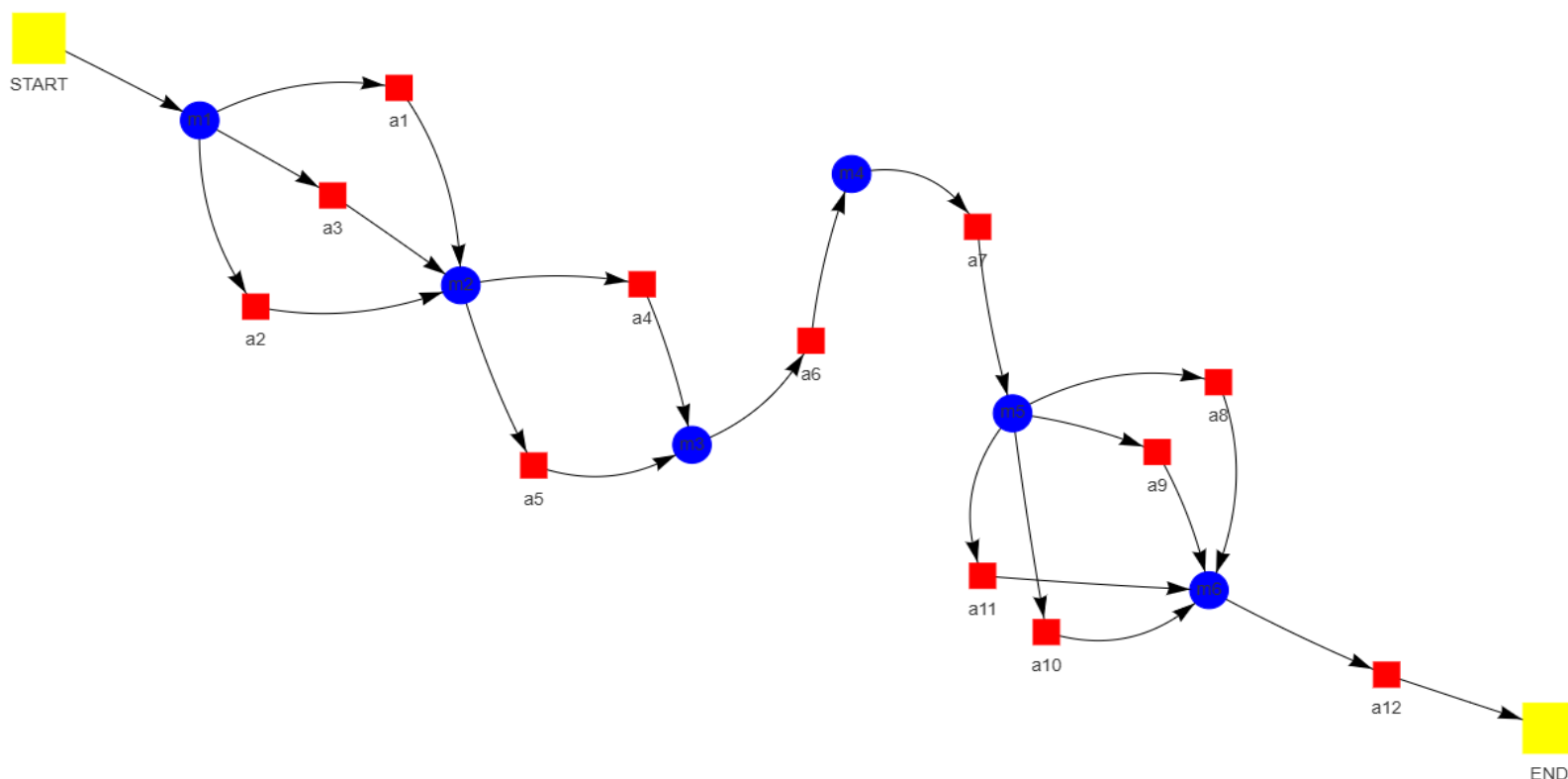
Milestone m5

- a8. Traffic Signaling: Port Knocking as used by the malware (T1205)
- a9. Data Obfuscation: Protocol Impersonation as used by the malware (T1001.003)
- a10. Encrypted Channel: Asymmetric Cryptography as used by the malware (T1573)
- a11. Protocol Tunneling as used by the malware (T1090.001)

Milestone m6

- a12. Exfiltration Over C2 Channel as used by the malware (T1041)

Attack Graph



Milestone *m1*

Attack Step *a1*

=====

Name: Command and Scripting Interpreter: Unix Shell as used by the malware

Description: The Pygmy Goat malware establishes remote command execution capabilities on infected devices through the utilization of "Command and Scripting Interpreter: Unix Shell" techniques. Exploitation of vulnerabilities in target systems grants initial access and potential privilege elevation. Subsequently, the malware creates a remote shell session employing either `/bin/sh` or `/bin/csh` interpreters. These shells facilitate the execution of arbitrary commands on compromised devices by attackers via established connections. Command execution enables a range of malicious activities, including data exfiltration, system manipulation, and lateral movement. Persistence mechanisms may be implemented to ensure continuous shell activity post-reboot, facilitating sustained remote control over infected systems.

Pre-Conditions:

- A Unix-like operating system is present.
- The malware is running on a system with a Unix-based operating system.

Post-Conditions:

- System instability
- Modified system startup scripts
- Data breaches
- Compromised security infrastructure
- Obfuscated command execution logs
- Compromised Fortinet certificate
- Loss of sensitive information
- Stolen user account data
- Backdoor communication logs
- Presence of "libsophos.so" file
- Modified database entries disabling automatic updates
- Altered SSH logs
- Encrypted ICMP packets
- Network disruption
- Unusual network traffic patterns
- Reputational damage

MITRE Technique

ID: T1059.004

Name: Command and scripting interpreter: unix shell

Description: Adversaries may abuse Unix shell commands and scripts for execution. Unix shells are the primary command prompt on Linux, macOS, and ESXi systems, though many variations of the Unix shell exist (e.g. sh, ash, bash, zsh, etc.) depending on the specific OS or distribution. Unix shells can control every aspect of a system, with certain commands requiring elevated privileges.

More info: <https://attack.mitre.org/techniques/T1059/004>

Attack Step a2

=====

Name: Scheduled Task/Job: Cron as used by the malware

Description: Crontab entries are potentially manipulated by malware to schedule malicious tasks. Compromised systems may exhibit crontab modifications that define tasks with specific time triggers and associated commands. Upon arrival of the designated time trigger, the defined command is executed automatically on behalf of the user account under which the crontab was altered. This execution can occur persistently even after system reboots, potentially enabling stealthy and continuous malicious operations.

Pre-Conditions:

- The attacker has write access to the /etc/crontab file or other crontab files.
- A Linux operating system is present.
- A crontab file is present on the system.
- Network connectivity may be required for downloading and executing malicious scripts.

Post-Conditions:

- Logs indicating unusual activity, including remote connections and file transfers.
- Remote control of compromised devices by attackers.

- Data exfiltration from compromised devices.
- Modified registry entries related to security settings or software installations.
- Altered system configurations.
- Modified firmware files.
- Compromised devices with persistent backdoors.
- Backdoor code injected into system processes (e.g., sshd).
- Presence of malicious files on affected devices.
- Network traffic logs showing communication with attacker-controlled servers.
- Potential for further attacks and exploitation leveraging the compromised systems.

MITRE Technique

ID: T1053.003

Name: Scheduled task/job: cron

Description: Adversaries may abuse the cron utility to perform task scheduling for initial or recurring execution of malicious code. The cron utility is a time-based job scheduler for Unix-like operating systems. The crontab file contains the schedule of cron entries to be run and the specified times for execution. Any crontab files are stored in operating system-specific file paths.

More info: <https://attack.mitre.org/techniques/T1053/003>

Attack Step a3

=====

Name: Inter-Process Communication as used by the malware

Description: Inter-process communication (IPC) between the parent process and any child processes forked by the malware is facilitated through the utilization of Unix sockets. This methodology enables secure and efficient data exchange among disparate components of the malware, obviating the need for shared memory or alternative methods that may present heightened security vulnerabilities.

Pre-Conditions:

- The malware has successfully infected the target device.
- A target device is running a Linux operating system.
- A network connection exists between the infected device and the attacker's command and control server.
- The target device has necessary system libraries and processes available for inter-process communication.

Post-Conditions:

- Potential for further attacks and lateral movement within the network.
- Presence of rootkits and other stealthy tools.
- Unusual network traffic patterns (e.g., encrypted ICMP packets, connections to malicious servers).
- Compromised Sophos Firewall devices.
- Altered system timestamps or logs.
- Remote control of infected devices by attackers.
- Modified system files (e.g., binaries, configuration files).
- New user accounts or processes with suspicious names.
- Data exfiltration from compromised systems.
- Log entries indicating unauthorized access attempts or successful compromises.
- Backdoor software remnants (e.g., "Pygmy Goat" malware).

MITRE Technique

ID: T1559

Name: Inter-process communication

Description: Adversaries may abuse inter-process communication (IPC) mechanisms for local code or command execution. IPC is typically used by processes to share data, communicate with each other, or synchronize execution. IPC is also commonly used to avoid situations such as deadlocks, which occurs when processes are stuck in a cyclic waiting pattern.

More info: <https://attack.mitre.org/techniques/T1559/>

Milestone *m2*

Attack Step *a4*

=====

Name: Hijack Execution Flow: Dynamic Linker Hijacking as used by the malware

Description: The execution flow of the sshd process is subverted by the malware through the exploitation of the LD_PRELOAD environment variable. A malicious library file, designated by the attacker-controlled LD_PRELOAD setting, is loaded prior to any libraries specified in the sshd program's dependencies. This preloading mechanism enables the malware to intercept and modify functions invoked by sshd, effectively usurping its intended operation.

Pre-Conditions:

- The malware has been deployed on the target system.
- The malware is present and capable of manipulating the dynamic linker.
- The target system is running a vulnerable software application.

Post-Conditions:

- Potential for further attacks and lateral movement within the network.
- Elevated privileges on compromised systems.
- Log entries indicating suspicious activity (failed login attempts, unauthorized access).
- New user accounts or modified existing user permissions.
- Encrypted files containing stolen data.
- Compromised systems with persistent backdoors.
- Data exfiltration from compromised systems.
- Modified system files (backdoor, configuration changes).
- Presence of malicious executables and scripts.
- Modified system registry settings.
- Unusual network traffic patterns (C2 communication, data exfiltration).
- Network connections to unknown or suspicious IP addresses.

MITRE Technique

ID: T1574.006

Name: Hijack execution flow: dynamic linker hijacking

Description: Adversaries may execute their own malicious payloads by hijacking environment variables the dynamic linker uses to load shared libraries. During the execution preparation phase of a program, the dynamic linker loads specified absolute paths of shared libraries from various environment variables and files, such as LD_PRELOAD on Linux or DYLD_INSERT_LIBRARIES on macOS. Libraries specified in environment variables are loaded first, taking precedence over system libraries with the same function name. Each platform's linker uses an extensive list of environment variables at different points in execution. These variables are often used by developers to debug binaries without needing to recompile, deconflict mapped symbols, and implement custom functions in the original library.

More info: <https://attack.mitre.org/techniques/T1574/006>

Attack Step *a5*

=====

Name: Boot or Logon Initialization Scripts as used by the malware

Description: The /bin/sshd_setup boot script is modified by the malware. A line is injected into this script that configures the LD_PRELOAD environment variable to reference the path of its malicious library. This manipulation enables the malware to intercept the functionality of the SSH daemon prior to its initiation, effectively injecting its own code into the process and usurping control over incoming SSH connections.

Pre-Conditions:

- The attacker's ability to deliver the malware payload to the target device.
- An attacker has successfully exploited the vulnerability to gain initial access to the device.
- The malware payload containing the boot or logon initialization scripts.
- The Sophos XG firewall is running a vulnerable version of firmware.

Post-Conditions:

- Altered database records and data inconsistencies
- Installation of backdoors and malware on affected devices
- Potential for further attacks and exploitation by the attackers
- Modified system files and configurations
- Compromised user accounts and credentials
- Backdoor communication logs
- Presence of malicious executables and scripts
- Unusual network traffic patterns and connections to command-and-control servers
- Log entries indicating unauthorized access and activity
- Data exfiltration from targeted organizations
- Compromised Sophos XG firewalls
- Disruption of services and operations within targeted organizations

MITRE Technique

ID: T1037.005

Name: Boot or logon initialization scripts: startup items

Description: Adversaries may use startup items automatically executed at boot initialization to establish persistence. Startup items execute during the final phase of the boot process and contain shell scripts or other executable files along with configuration information used by the system to determine the execution order for all startup items.

More info: <https://attack.mitre.org/techniques/T1037/005>

Milestone *m3*

Attack Step *a6*

=====

Name: Network Sniffing as used by the malware

Description: Network traffic interception is facilitated by the Pygmy Goat malware through the utilization of libpcap. A Berkeley Packet Filter (BPF) expression, specifically tailored to designated protocols, IP addresses, ports, or packet content, serves as a filter for captured network traffic. The pcap_open and pcap_loop functions from the libpcap library are employed to establish a live network interface and continuously capture packets conforming to the defined BPF filter. Subsequent analysis of captured packets is conducted by the malware in accordance with its objectives, potentially encompassing the extraction of sensitive information such as usernames, passwords, or financial data. Extracted data is subsequently transmitted to an attacker-controlled command-and-control (C2) server for further processing and exploitation.

Pre-Conditions:

- The target device is connected to a network.
- The malware has the capability to capture network packets.
- A network interface card (NIC) is present and operational on the infected device.
- The malware has been successfully installed on a target device.

Post-Conditions:

- Presence of "libsophos.so" library in memory and filesystem.
- Logs indicating successful execution of malicious commands.
- Modified crontab entries for scheduled tasks.
- Remote control of infected devices.
- Unusual ICMP packet patterns.
- Persistent backdoor access for attackers.
- Potential disruption of critical infrastructure or services.
- Compromised Sophos XG firewalls.
- Data exfiltration from targeted networks.
- Altered SSH logs with unusual activity.
- Network traffic to attacker-controlled C2 servers.
- Modified system files (e.g., /bin/sshd, startup scripts).
- Packet captures containing sensitive data.
- Presence of suspicious binaries downloaded from internal web server.

MITRE Technique

ID: T1040

Name: Network sniffing

Description: Adversaries may passively sniff network traffic to capture information about an environment, including authentication material passed over the network. Network sniffing refers to using the network interface on a system to monitor or capture information sent over a wired or wireless connection. An adversary may place a network interface into promiscuous mode to passively access data in transit over the network, or use span ports to capture a larger amount of data.

More info: <https://attack.mitre.org/techniques/T1040/>

Milestone *m4*

Attack Step a7

=====

Name: Archive Collected Data: Archive via Library as used by the malware

Description: Data collected by the malware is archived via compression utilizing the LZO1X library.

Pre-Conditions:

- The malware has sufficient permissions to write archive files.
- The malware has collected data.
- The malware is running in an environment with a suitable operating system.

Post-Conditions:

- Altered firewall rules allowing unauthorized traffic.
- Compromised Sophos firewalls granting unauthorized access to internal networks.
- Long-term espionage and intelligence gathering by the threat actor.
- Potential disruption of critical infrastructure and services.
- Unusual ICMP packet activity.
- New cron jobs scheduled for malicious tasks.
- Modified firmware upgrade process with embedded backdoor.
- Data exfiltration from compromised systems.
- Logs indicating unusual network activity, including connections to C2 servers.
- Presence of Pygmy Goat malware code within compromised systems.
- Modified system files with backdoor functionality ("nasmd" instead of "nasm").

MITRE Technique

ID: T1560.002

Name: Archive collected data: archive via library

Description: An adversary may compress or encrypt data that is collected prior to exfiltration using 3rd party libraries. Many libraries exist that can archive data, including Python rarfile , libzip , and zlib . Most libraries include functionality to encrypt and/or compress data.

More info: <https://attack.mitre.org/techniques/T1560/002>

Milestone *m5*

Attack Step *a8*

=====

Name: Traffic Signaling: Port Knocking as used by the malware

Description: Port knocking is employed by Pygmy Goat for communication with its command-and-control (C2) server. This technique involves the transmission of specific ICMP packet sequences ("knocks") to a target device. Upon receiving these predefined sequences, a correctly configured target device responds by opening a designated port, facilitating a secure connection establishment. Pygmy Goat implements this technique by establishing an ICMP raw socket on the infected firewall, enabling direct reception and interpretation of ICMP packets without traversing standard network routing protocols. Encrypted ICMP packets are transmitted from the C2 server to the infected device. These packets contain information regarding the C2 server address and an encryption key utilized for subsequent data exchange between Pygmy Goat and the C2 server. Upon receipt of a valid encrypted packet, Pygmy Goat decrypts it using the embedded key. Subsequently, a secure TLS connection is established (utilizing SSH as a cover) with the specified C2 server address. The effectiveness of this method stems from its stealthy nature. ICMP packets are frequently disregarded by firewalls and intrusion detection systems due to their common usage in network diagnostics rather than malicious activities. Furthermore, the encrypted nature of the "knocks" hinders analysis of communication and identification of the C2 server address.

Pre-Conditions:

- The malware is running on a compromised system.
- The attacker knows the target system's IP address.
- The compromised system has network connectivity.
- A pre-defined port knocking sequence agreed upon by the attacker and the compromised system.
- A compromised system with the Pygmy Goat malware installed.

Post-Conditions:

- Persistent backdoor access to the compromised Sophos XG firewall.
- Traces of deleted or modified system files.
- New crontab entries scheduling malicious tasks.
- Modified firewall rules allowing unauthorized access.
- Log files containing suspicious activity related to the backdoor and data exfiltration.
- Exfiltration of sensitive data from the network.
- Disruption of network services and operations.
- Modified /etc/passwd file with new user accounts.
- Backdoor executable (e.g., "pygmy_goat") in a non-standard location.
- Network traffic logs showing connections to the attacker's command and control server.
- Potential for lateral movement and compromise of other systems on the network.
- Loss of trust in security infrastructure.

MITRE Technique

ID: T1205

Name: Traffic signaling

Description: Adversaries may use traffic signaling to hide open ports or other malicious functionality used for persistence or command and control. Traffic signaling involves the use of a magic value or sequence that must be sent to a system to trigger a special response, such as opening a closed port or executing a malicious task. This may take the form of sending a series of packets with certain characteristics before a port will be opened that the adversary can use for command and control. Usually this series of packets consists of attempted connections to a predefined sequence of closed ports (i.e. Port Knocking), but can involve unusual flags, specific strings, or other unique characteristics. After the sequence is completed, opening a port may be accomplished by the host-based firewall, but could also be implemented by custom software.

More info: <https://attack.mitre.org/techniques/T1205/>

Attack Step a9

=====

Name: Data Obfuscation: Protocol Impersonation as used by the malware

Description: Protocol impersonation is employed by Pygmy Goat to obfuscate its malicious activities. This technique involves mimicking legitimate SSH communication to evade detection. A fake SSH handshake is initiated upon an attacker's attempt to connect via SSH to a compromised Sophos XG firewall. Pre-set responses are transmitted, simulating the behavior of a standard SSH server during the initial authentication phase. Subsequently, a genuine TLS (Transport Layer Security) handshake is established over this fabricated SSH channel. This deviates from typical protocol flow where the client initiates the TLS handshake after a successful SSH connection. Command execution is facilitated once the TLS connection is established. The attacker transmits commands through this encrypted channel, which are then executed by Pygmy Goat on the compromised firewall, enabling remote control and data exfiltration. Network monitoring tools often focus on identifying known SSH connections and traffic patterns, rendering Pygmy Goat's initial mimicry effective in bypassing these defenses. The utilization of TLS encryption further obscures communication between the attacker and the malware, complicating analysis.

Pre-Conditions:

- Network connectivity between the infected system and the attacker's command and control (C2) server.
- The Pygmy Goat malware executable.
- A Linux-based system with SSH enabled.
- The malware is running on a target system.
- The target system is configured to use SSH.
- The target system has network connectivity.

Post-Conditions:

- New user accounts or modified existing ones with elevated privileges
- Potential compromise of other devices on the network
- Data exfiltration from the compromised device
- Network traffic analysis revealing data exfiltration attempts
- Persistent backdoor access to the device for the attacker
- Presence of malicious files (e.g., "nasmd", rootkit)
- Compromised Sophos XG firewall
- Modified system files (SSH, SSHD, binaries)
- Logs showing unusual activity, including connections to unknown IP addresses
- Altered firewall rules allowing unauthorized traffic

- Modified configuration files for cron jobs executing attacker-provided scripts
- Presence of custom-built rootkit mimicking legitimate Sophos product behavior
- Backdoor communication logs in system and application logs

MITRE Technique

ID: T1001.003

Name: Data obfuscation: protocol or service impersonation

Description: Adversaries may impersonate legitimate protocols or web service traffic to disguise command and control activity and thwart analysis efforts. By impersonating legitimate protocols or web services, adversaries can make their command and control traffic blend in with legitimate network traffic.

More info: <https://attack.mitre.org/techniques/T1001/003>

Attack Step a10

=====

Name: Encrypted Channel: Asymmetric Cryptography as used by the malware

Description: Encrypted communication between the malware and its command-and-control (C2) server is facilitated through an asymmetric cryptography protocol employing TLS. Data transmission utilizes a public key for encryption by the malware and a corresponding private key held by the C2 server for decryption. The TLS protocol establishes a secure connection, subsequently encrypting all exchanged data between the malware and the C2 server.

Pre-Conditions:

- The malware has access to its private key.

Post-Conditions:

- Backdoor executables or scripts.
- Potential for further attacks and lateral movement within the network.
- New user accounts created.
- Unusual file transfers between compromised systems and external destinations.
- Modified system files (e.g., SSH daemon, firmware).
- Remote control of infected devices by attackers.
- Registry modifications indicating malware presence.
- Compromised systems with persistent backdoors.
- Data exfiltration from compromised systems.
- Altered log files with suspicious activity.
- Network traffic logs showing communication with attacker-controlled servers.
- Presence of rootkits or other stealthy tools.

MITRE Technique

ID: T1573

Name: Encrypted channel

Description: Adversaries may employ an encryption algorithm to conceal command and control traffic rather than relying on any inherent protections provided by a communication protocol. Despite the use of a secure algorithm, these implementations may be vulnerable to reverse engineering if secret keys are encoded and/or generated within malware samples/configuration files.

More info: <https://attack.mitre.org/techniques/T1573/>

Attack Step a11

=====

Name: Protocol Tunneling as used by the malware

Description: A reverse SOCKS5 proxy server is established by Pygmy Goat upon successful infection of a Linux-based device, potentially exploiting vulnerabilities such as CVE-2022-1040. Upon establishment within the compromised system, a SOCKS5 server is configured to accept connections from external devices controlled by the attacker. An attacker's machine initiates a connection to the Pygmy Goat-infected device utilizing a SOCKS5 client. Subsequently, all data transmitted from the attacker's machine through the SOCKS5 client is relayed via the Pygmy Goat server resident on the infected device. This process effectively tunnels the traffic, obscuring its origin and destination from network monitoring tools. This configuration enables the attacker to access internet resources or other networks as if directly connected from their own machine. The aforementioned functionality presents several significant implications: Traffic originating from the infected device is presented, thereby hindering traceback efforts directed at the attacker. Security measures such as firewalls and intrusion detection systems may fail to detect malicious traffic traversing a seemingly legitimate SOCKS5 connection. The attacker can maintain persistent connectivity with the compromised device, facilitating ongoing espionage or data exfiltration activities.

Pre-Conditions:

- The malware is present on a target system.
- A C2 server is accessible to the malware.
- An active internet connection on the infected system.
- The target system has network connectivity.
- A compromised system with the Pygmy Goat malware installed.

Post-Conditions:

- New user accounts created.
- Unusual log entries in system logs and application logs.
- Modified crontab entries for scheduled tasks.
- Data exfiltration from compromised devices.
- Remote code execution on compromised devices.
- Modified system files.
- Evidence of TLS connections to C2 servers.
- Altered firewall rules.
- Installation of additional malware on compromised devices.
- Traces of ICMP communication with encrypted payloads.
- Presence of a web shell on the device.
- Disruption of network services.
- Network traffic to known malicious IP addresses.
- Compromised Sophos XG firewall devices.
- Presence of new executables or scripts.

MITRE Technique

ID: T1090.001

Name: Proxy: internal proxy

Description: Adversaries may use an internal proxy to direct command and control traffic between two or more systems in a compromised environment. Many tools exist that enable traffic redirection through proxies or port redirection, including HTRAN, ZXProxy, and ZXPortMap. Adversaries use internal proxies to manage command and control communications inside a compromised environment, to reduce the number of simultaneous outbound network connections, to provide resiliency in the face of connection loss, or to ride over existing trusted communications paths between infected systems to avoid suspicion. Internal proxy connections may use common peer-to-peer (p2p) networking protocols, such as SMB, to better blend in with the environment.

More info: <https://attack.mitre.org/techniques/T1090/001>

Milestone *m6*

Attack Step *a12*

=====

Name: Exfiltration Over C2 Channel as used by the malware

Description: The specific method employed for data exfiltration over the C2 channel within the "Pacific Rim" malware campaign remains undisclosed. However, potential mechanisms can be inferred from the provided context. Encrypted ICMP packets utilized for communication with the C2 server may also encapsulate exfiltrated data, thereby concealing it within legitimate network traffic. Alternatively, the "EarthWorm" component, which establishes a SOCKS5 proxy tunnel between the infected device and the C2 server, could facilitate secure data transfer via this established connection. A comprehensive technical analysis of the malware, encompassing its code, network traffic patterns, and communication protocols, is required to ascertain the precise exfiltration mechanisms employed.

Pre-Conditions:

- The malware has successfully established a connection with the C2 server.
- A functioning C2 server controlled by the threat actors.
- The malware possesses the capability to encode and transmit data over the network.
- Sensitive data is available on the compromised device.
- An active internet connection on the compromised device.
- A compromised Sophos XG firewall device running the Pygmy Goat malware.

Post-Conditions:

- Modified system files with backdoor functionality.
- Increased risk of further attacks and lateral movement within the network.
- Modified system startup scripts with LD_PRELOAD variable.
- Files containing attacker-specific code or configuration data.
- Persistent backdoor access for attackers.
- Network traffic to C2 server using ICMP port knocking technique.
- Altered SSH daemon logs indicating unusual activity and command execution.
- Potential disruption of network services.
- Compromised Sophos XG firewall devices.
- Presence of malicious ELF shared object (libsophos.so) in memory and filesystem.
- Data exfiltration from compromised networks.

MITRE Technique

ID: T1041

Name: Exfiltration over c2 channel

Description: Adversaries may steal data by exfiltrating it over an existing command and control channel. Stolen data is encoded into the normal communications channel using the same protocol as command and control communications.

More info: <https://attack.mitre.org/techniques/T1041/>